

W18D1 - (extra) - Business Continuity e Disaster Recovery

metasploitable - theory

Evaluation

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 03/11/2025 - duration (days): 1

Contents

Sommario	1
Business Continuity	1
Disaster Recovery	1
Principali differenze	2
ICT Readiness for Business Continuity - ISO/IEC 27031	2
La normativa ISO/IEC 27031	3
Un esempio di Business Continuity Plan	4

Sommario

Andiamo a vedere assieme i concetti di **Business Continuity** (BC) e **Disaster Recovery** (DR).

Business Continuity

La Business Continuity è una pratica che mira ad assicurare che un'azienda possa continuare ad operare anche durante un momento di crisi inaspettato come un disastro naturale o un attacco hacker. Comporta la pianificazione accurata delle operazioni per la gestione del rischio e per l'operatività delle funzioni principali dell'azienda.

La BC comprende la rilevazione dei rischi, la pianificazione delle operazioni ordinarie così come l'implementazione di misure a sostegno della resilienza dell'operatività dell'azienda.

Disaster Recovery

La Disaster Recovery è un sotto-set della BC, il cui focus principale è il ripristino dell'infrastruttura IT dopo un evento dannoso, sia esso un disastro naturale o un attacco hacker.

La DC include strategie di backup, ripristino software, sostituzione hardware e tutte quelle pratiche volte al ripristino dei sistemi nel minor tempo possibile per ridurre al minimo il downtime e l'interruzione dei servizi.

Principali differenze

Di seguito alcune delle principali differenze tra Business Continuity e Disaster Recovery.

	Business Continuity	Disaster Recovery
Scopo	Assicurare la continuazione delle operazioni durante un evento disastroso, mantenendo attive le funzioni critiche dell'azienda.	Ripristino dell'infrastruttura IT a seguito di un disastro o di un attacco, principalmente attraverso l'utilizzo di sistemi di backup e sostituzione di sistemi compromessi allo scopo di minimizzare il downtime.
Oggetto	Vasto insieme di potenziali rischi, tentando di coprire tutti gli aspetti dell'operatività dell'azienda in modo da garantire la continuità operativa.	Focus concentrato sull'infrastruttura IT e il recupero dei dati, nel contesto del piano generale di continuità operativa dell'azienda.
Obbiettivi	Prepararsi per le attività aziendali, pianificare proattivamente per mantenere la produttività durante le crisi, includendo la gestione delle comunicazioni tra i reparti, i fornitori e il management.	Ripristino dei sistemi IT rapidamente ed in maniera efficiente in seguito ad un disastro. Può includere ripristino dei dati da un backup, sostituzione di hardware danneggiato o software compromesso.
Finestra Temporale	Impegno continuo e costante durante tutto il ciclo di vita di un'azienda, al fine di essere preparati a possibili eventi catastrofici.	In seguito ad un evento catastrofico, si richiede risposta immediata e un processo pianificato di ripristino delle operazioni.
Relazione	La BC comprende la DR come uno degli aspetti di una visione più vasta, includendo anche considerazioni operative che vanno oltre il ripristino dell'infrastruttura IT.	la DR è spesso inclusa nel framework della BC, essendo un aspetto di un quadro più ampio dell'organizzazione aziendale nell'ottica della resilienza operativa.

ICT Readiness for Business Continuity - ISO/IEC 27031

Al giorno d'oggi, le aziende devono disporre di piani completi di continuità operativa IT per mantenere la resilienza del business. Andiamo quindi ad analizzare l'importanza della preparazione alle tecnologie dell'informazione e della comunicazione (**Information and Communication Technology**, ICT in breve.) per la continuità aziendale e il modo in cui lo standard internazionale ISO/IEC 27031 contribuisce al raggiungimento di questo obiettivo.

In caso di incidenti o crisi imprevisti, le aziende si affidano ai propri sistemi IT per le operazioni e le comunicazioni essenziali. Un'infrastruttura IT ben progettata può aiutare le organizzazioni a mantenere la continuità garantendo un accesso ininterrotto a dati, applicazioni e risorse critiche.

Inoltre l'identificazione e la gestione proattive delle potenziali minacce riducono significativamente i rischi e minimizzano i potenziali danni. Sviluppando piani di emergenza personalizzati basati sulla valutazione dei rischi, le aziende possono rispondere in modo più efficace alle interruzioni riducendo al minimo i tempi di inattività e le perdite finanziarie.

Un aspetto fondamentale è la collaborazione e comunicazione tra dipendenti, clienti e fornitori in situazioni di crisi. Una comunicazione e una cooperazione efficaci tra tutte le parti coinvolte contribuiscono a garantire operazioni fluide nei periodi difficili. Le soluzioni ICT facilitano la condivisione delle informazioni e il processo decisionale in tempo reale, contribuendo così agli sforzi complessivi di pianificazione della continuità aziendale.

Una pianificazione efficace è fondamentale per mantenere la continuità dei servizi in condizioni di stress e può aumentare la fiducia e la lealtà delle parti interessate. Implementando piani BC affidabili, le organizzazioni dimostrano il loro impegno per la resilienza, che ha un impatto positivo sulla percezione pubblica e sul valore del marchio.

A tale scopo vengono redatti dei documenti di continuità ben definiti, che forniscono una guida passo passo per la gestione delle interruzioni e il ripristino dei sistemi IT essenziali. Questi manuali possono aiutare le aziende a prepararsi a vari scenari potenziali, consentendo loro di riprendere rapidamente le operazioni dopo una crisi.

La normativa ISO/IEC 27031

La norma ISO/IEC 27031 offre un approccio completo per le organizzazioni che desiderano gestire in modo efficace i rischi legati alla continuità dei servizi IT. Seguendo queste buone pratiche, le aziende possono aumentare la propria resilienza contro incidenti imprevisti e migliorare la propria capacità di riprendersi dalle interruzioni.

Questo standard incoraggia l'identificazione proattiva delle potenziali minacce e stabilisce processi per valutare i rischi associati. Sulla base di questa analisi, le organizzazioni possono ideare strategie di risposta mirate che riducano al minimo gli impatti delle interruzioni.

Una comunicazione efficace è fondamentale durante le crisi e la norma ISO/IEC 27031 sottolinea l'importanza di coinvolgere tutte le parti interessate per ottenere una gestione fluida delle crisi e sforzi di ripresa.

La revisione e il perfezionamento regolari dei piani di continuità aziendale garantiscono inoltre un allineamento continuo con gli obiettivi organizzativi e l'evoluzione dei rischi. La norma ISO/IEC 27031 promuove attività continue di monitoraggio, valutazione e miglioramento per mantenere un piano di continuità del servizio IT solido e aggiornato.

In conclusione, una solida preparazione IT è essenziale per mantenere la continuità aziendale. Seguendo le migliori pratiche delineate nella norma ISO/IEC 27031, le organizzazioni possono sviluppare piani completi di continuità operativa che incorporino considerazioni ICT, proteggano le funzioni critiche e supportino gli obiettivi aziendali generali.

Un esempio di Business Continuity Plan

Secondo la norma ISO/IEC 27031, un approccio globale allo sviluppo e all'implementazione di un piano di continuità operativa (BCP) dovrebbe prevedere i seguenti passaggi:

1. **Ambito** - Identificare e definire l'ambito del BCP, compresi i sistemi ICT critici dell'organizzazione e le loro dipendenze.
2. **Analisi dell'impatto aziendale**: valutare il potenziale impatto sull'azienda derivante dalle interruzioni di questi sistemi ICT.
3. **Politica** - Stabilire politiche per la gestione e la continuità delle informazioni.
4. **Pianificazione** - Sviluppare un piano dettagliato per mantenere le operazioni del sistema ICT durante un incidente o un'interruzione. Ciò include l'identificazione di siti alternativi, fonti di energia, metodi di telecomunicazione, ecc.
5. **Formazione e sensibilizzazione**: garantire che il personale interessato sia formato sui propri ruoli e responsabilità nell'ambito del BCP, compresa una formazione regolare di sensibilizzazione per tenerlo aggiornato sui potenziali rischi e sulle strategie di risposta.
6. **Esercizi e test**: eseguire test ed esercizi periodici del BCP per garantirne l'efficacia e individuare aree di miglioramento.
7. **Revisione e manutenzione**: rivedere, aggiornare e mantenere regolarmente il BCP per riflettere i cambiamenti nei sistemi ICT o nell'ambiente aziendale dell'organizzazione.

Si conclude l'approfondimento facoltativo di oggi.

Alla prossima.

